



EISI – M3.3

GESTION DES RISQUES & CONFORMITÉ

MAI 2025
S. VOGELSINGER

INTRODUCTION

Programmation

15/04/25	Cartographie et diagnostic du SI
12/05/25	Gestion des risques et conformité
12/06/25	Élaboration d'une nouvelle stratégie informatique
13/06/25	Transformation digitale et méthodologies agiles (ITSM, ITIL, SAFE)
07/07/25	Présentation des préconisations et soutenance
18/08/25	Synthèse et entraînement à la soutenance



CADRE DE LA GESTION DES RISQUES

Sécurité du SI, Gestion de risques

**VOTRE AVIS
NOUS INTÉRESSE**



INTRODUCTION

Objectifs

- Situer la sécurité du SI dans la stratégie globale de l'entreprise et du SI
- Comprendre et mobiliser les concepts fondamentaux de gestion des risques
- Identifier les exigences clés des réglementations françaises et européennes et leur impact sur la gestion des risques
- Appliquer une démarche de gestion des risques à un cas concret



INTRODUCTION

Déroulé de la journée

- Le cadre de la gestion des risques
- La démarche de gestion des risques
- Conformité, référentiels et réglementations
- La méthode EBIOS, présentation et mise en pratique



CADRE DE LA GESTION DES RISQUES

SSI, stratégie globale de l'entreprise et du SI

Pilier stratégique au service des enjeux globaux de l'entreprise

Innovation produit (éclairage connecté, IoT, IA) > Intégrer l'IoT, la data et l'IA dans le SI

- Réduire des risques liés à l'exploitation des technologies,
- Garantir la conformité réglementaire,
- Créer les conditions de confiance indispensables au développement numérique de l'entreprise



CADRE DE LA GESTION DES RISQUES

SSI, stratégie globale de l'entreprise et du SI

Alignement avec les priorités stratégiques de l'entreprise

- Assurer la **continuité d'activité** face aux menaces numériques (ransomware, perte de données)
- Protéger les **données stratégiques** (clients, offres, innovation) dans un contexte de forte concurrence
- Renforcer la **conformité** (normes ISO, RGPD, NIS2 ...) indispensable à la crédibilité de l'entreprise vis-à-vis de ses clients publics et privés
- Sécuriser l'**ouverture de l'entreprise** vers des solutions cloud, des objets connectés ou des partenaires distants



CADRE DE LA GESTION DES RISQUES

SSI, stratégie globale de l'entreprise et du SI

Composante structurante de la stratégie SI

A intégrer dans:

- la **gouvernance du SI** (politiques de sécurité, audits réguliers, indicateurs de pilotage)
- l'**architecture du SI et des projets SI** (évaluation des risques, by design, by default)
- La **montée en compétence** des équipes internes et des utilisateurs (sensibilisation, processus clairs, supervision)



CADRE DE LA GESTION DES RISQUES

SSI, stratégie globale de l'entreprise et du SI

Levier de transformation numérique et d'agilité

- Un **facteur de confiance** pour innover (produits connectés)
- Un **argument commercial** différenciant auprès de clients sensibles à la conformité
- Un **socle d'agilité**, garantissant que l'évolution du SI reste maîtrisée (cloud, multisite, mobilité)



CADRE DE LA GESTION DES RISQUES

Analyse de risques: le point de départ

- Identification des risques
- Priorisation des risques
- Plan de traitement des risques



CADRE DE LA GESTION DES RISQUES

Les enjeux de la gestion des risques

Indispensable pour **comprendre les risques, mesurer le niveau de sécurité du SI** et **déterminer les actions de mitigations** à entreprendre pour améliorer la sécurité globale du SI de l'organisation.

- Protection du patrimoine informationnel
- Conformité réglementaire
- Continuité de l'activité
- Optimisation des investissements (mesures)
- Confiance des parties prenantes
- Compétitivité, pérennité



CADRE DE LA GESTION DES RISQUES

Sécurité globale du SI - Principes de SSI

DÉFENSE DANS
LA PROFONDEUR

Cybersécurité

Environnements connectés à Internet

Sécurité de l'information

Classification des données

Sécurité logique & applicative

Développement, cryptographie, accès, sauvegarde, incidents ...

Sécurité des réseaux

Accès, transport

Sécurité de l'exploitation

Outils & procédures exploitation, maintenance, tests, performance

Sécurité physique & environnementale

Accès locaux, équipements, énergie, incendie, maintenance ...

MINIMISATION

MOINDRE
PRIVILÈGE

SECURITY
BY DESIGN

SECURITY
BY DEFAULT

Référence: Cybersécurité – S. GHERNAOUTI

IDENTIFICATION DES RISQUES & CONFORMITÉ



CADRE DE LA GESTION DES RISQUES

La cybersécurité

La cybersécurité désigne le rôle de l'ensemble des lois, politiques, outils, dispositifs, concepts et mécanismes de sécurité, méthodes de gestion des risques, actions, formations, bonnes pratiques et technologies qui peuvent être utilisés pour protéger les personnes et les actifs informatiques matériels et immatériels (connectés directement ou indirectement à un réseau) avec un objectif de DICT.



CADRE DE LA GESTION DES RISQUES

Acteurs dans entreprise & son écosystème

- RSSI
- DG
- DSI
- Métier / responsables opérationnels
- Utilisateurs clés / Référents Métier

- Consultants
- Prestataires
- Assureurs
- Régulateurs



CADRE DE LA GESTION DES RISQUES

Actifs - Valeur Métier & Bien support



Valeurs Métier [VM]

Capital immatériel
(élément à protéger)



Biens support [BS]

Composant du SI

Planification de la production
Fichier clients



CADRE DE LA GESTION DES RISQUES

Vulnérabilité, menace et risque

VULNÉRABILITÉ = **Faute**, par malveillance ou maladresse, dans les spécifications, la conception, la réalisation, l'installation ou la configuration d'un système, ou dans la façon de l'utiliser .

- Faible qui fragilise la ressource concernée (positionnement d'un serveur, choix d'un logiciel, recrutement d'un personnel, contrôle d'accès ...)

MENACE = tout événement ou circonstance pouvant causer un préjudice, un dommage ou une atteinte à un actif, une organisation ou une personne.

- Menaces intentionnelles = actes de malveillance (phishing, ransomware, déni de service)
- Menaces accidentelles = catastrophes naturelles (inondations, tempêtes), erreurs humaines
- ANSSI > toute intention hostile de nuire dans le cyber espace

RISQUE = possibilité qu'une vulnérabilité soit exploitée par une menace

- ANSSI > Possibilité qu'un événement redouté survienne et que ses effets impactent les missions de l'objet de l'étude (scénario de risques)





CADRE DE LA GESTION DES RISQUES

Formulation d'un risque

ACTIF(S) + VULNERABILITE + MENACE + IMPACT => SCENARIO DE RISQUE

- 1 – Risque accidentel : incendie d'un bâtiment de production
- 2 – Risque intentionnel : vol d'une voiture de fonction
- 3 – Risque intentionnel : vol de données confidentielles (portable)





CADRE DE LA GESTION DES RISQUES

Formulation d'un risque

Local de production (actif secondaire)

+ Absence de détection

+ Court-circuit

=> Interruption de l'activité

Risque d'incendie accidentel pouvant causer l'indisponibilité des locaux et une perte d'exploitation





CADRE DE LA GESTION DES RISQUES

Formulation d'un risque

Véhicule de la société

+ stationné porte non verrouillé, sans alarme, clé ...

+ individu malveillant (opportuniste)

⇒ Non livraison, préjudice financier

Risque de vol d'un véhicule professionnel, entraînant une perte de service et un préjudice financier





CADRE DE LA GESTION DES RISQUES

Formulation d'un risque

Données de conception de nouveaux produits (fichiers CAO, prototypes), Ordinateur portable contenant ces fichiers

+ Données non chiffrées, pas de verrouillage automatique, sans surveillance

+ Concurrent (salon)

⇒ Fuite d'informations stratégiques, perte d'avantage concurrentiel

Risque de compromission des données de R&D suite au vol d'un poste non sécurisé contenant des fichiers sensibles



CADRE DE LA GESTION DES RISQUES

Besoins ou critères de sécurité

VM associée à un ou plusieurs besoins de sécurité

- Disponibilité > accessible au moment voulu
- Intégrité > exactitude, modifiable par seuls autorisés
- Confidentialité > accessible aux seuls autorisés
- Traçabilité > suivi des activités



CADRE DE LA GESTION DES RISQUES

Besoins ou critères de sécurité - Niveaux

	Disponibilité	Intégrité	Confidentialité	Traçabilité
1	Indisponibilité > 48h	Peut ne pas être intègre	Public (pas de protection)	Pour information
2	Indisponibilité entre 24h & 48h	Erreur détectable	Restreint (interne & partenaires)	Entité identifiée
3	Indisponibilité entre 12h & 24h	Erreur détectable & corrigeable	Confidentiel (projet)	Auteur identifié
4	Indisponibilité inférieur à 12h	Intègre & prouvée	Secret (besoin d'en connaître)	Preuve opposable



CADRE DE LA GESTION DES RISQUES

Événement redouté et impact

ÉVÉNEMENT REDOUTÉ = associé à une valeur métier, il traduit l'atteinte à un besoin de sécurité d'une valeur métier (indisponibilité d'un service, modification illégitime du seuil d'une valeur critique d'un processus industriel, divulgation de données classifiées)

GRAVITÉ = estimation du niveau et de l'intensité des effets d'un risque. La gravité fournit une **mesure des impacts préjudiciables** perçus, qu'ils soient directs ou indirects.

$$\text{RISQUE} = \text{GRAVITE} \times \text{PROBABILITE D'OCCURENCE}$$



CADRE DE LA GESTION DES RISQUES

Evénement redouté - Echelle de gravité

	Description détaillée de l'échelle
Mineure (1/4)	Aucun impact opérationnel ni sur les performances de l'activité ni sur la sécurité des personnes et des biens. La société surmontera la situation sans trop de difficultés (consommation des marges).
Significative (2/4)	Dégradation des performances de l'activité sans impact sur la sécurité des personnes et des biens. La société surmontera la situation malgré quelques difficultés (fonctionnement en mode dégradé).
Grave (3/4)	Forte dégradation des performances de l'activité, avec d'éventuels impacts significatifs sur la sécurité des personnes et des biens. La société surmontera la situation avec de sérieuses difficultés (fonctionnement en mode très dégradé).
Critique (4/4)	Incapacité pour la société d'assurer tout ou partie de son activité, avec d'éventuels impacts graves sur la sécurité des personnes et des biens. La société ne surmontera vraisemblablement pas la situation (sa survie est menacée).



CADRE DE LA GESTION DES RISQUES

Mesure de sécurité

Disposition technique, organisationnelle ou humaine mise en œuvre pour réduire la probabilité d'occurrence ou l'impact d'un incident de sécurité

- **technique** = repose sur des composants techniques (matériels, logiciels, réseaux) > mise en place d'un firewall, 2FA
- **organisationnelle** = repose sur des politiques internes, des procédures > politique de gestion des habilitations, revue trimestrielle des droits d'accès, PCA
- **humaine** = formation des utilisateurs

Certaines mesures peuvent se renforcer mutuellement en agissant selon des axes complémentaires gouvernance, protection, défense (détection & réaction), résilience.



CADRE DE LA GESTION DES RISQUES

Les méthodes d'analyse de risque

Critère	Analyse qualitative	Analyse quantitative
Principe	Évaluation gravite et vraisemblance des scénarios de risque à l'aide d'échelles ordonnées (ex. : faible / moyen / fort) pour prioriser le traitement.	Évaluation basée sur des valeurs chiffrées (euros, probabilités). Attribution de valeur monétaire
Méthodes	ISO 27005, EBIOS RM, NIST CSF	FAIR
Données requises	Peu de données chiffrées, nécessite la participation d'experts métiers et techniques	Données quantitatives fiables : historiques d'incidents, coûts, probabilités, statistiques
Temps de mise en œuvre	Relativement rapide et adaptée aux moyens limités	Plus longue, demande ressources spécialisées et données solides
Résultat obtenu	Classement des risques (ex. : risque élevé, modéré, faible).	Montant estimé de la perte annuelle attendue (€), probabilité exacte d'occurrence.
Exploitation	Idéale pour définir des priorités de traitement dans un contexte avec peu de données.	Aide à la décision économique (ex. : retour sur investissement d'une mesure de sécurité).
Limites	Subjectivité, risque d'incohérences. Moins convaincante pour arbitrer des budgets.	Forte dépendance à la qualité et disponibilité des données. Complexité mathématique.



CADRE DE LA GESTION DES RISQUES

FAIR – Etapes (très) simplifiées

1 - Fréquence d'occurrence estimée :

- 2 attaques probables par an
- Taux de réussite estimé : 50%

=> **Fréquence de perte** : $2 \times 0,5 = 1$ incident/an

2 - Impact estimé par incident :

- Perte directe (arrêt activité, restauration, rançon) : 30 000 €
- Perte indirecte (image, perte clients, etc.) : 20 000 €

=> **Impact total** : $30\,000 + 20\,000 = 50\,000$ €

3 - Perte annuelle attendue

=> $1 \times 50\,000 \text{ €} = 50\,000 \text{ €/an}$

Conclusion : La PME peut estimer qu'un ransomware coûte en moyenne 50 000 € par an, et décider si une solution à 10 000 €/an (sauvegarde renforcée, EDR...) est rentable.



DEMARCHE DE GESTION DES RISQUES

La norme ISO 27005 – Analyse quantitative

ISO 27005:2022 - Sécurité de l'information, cybersécurité et protection de la vie privée - Préconisations pour la gestion des risques liés à la sécurité de l'information

Démarche de gestion des risques liés aux systèmes d'information. Certifiable.

S'appuie sur les lignes directrices de ISO 27001 (SMSI) et ISO 27002 (Mesures de sécurité)



DEMARCHE DE GESTION DES RISQUES

ISO 27005 - Contexte

L'ISO 27005 appelle à identifier les exigences de base des parties intéressées, en intégrant à la fois des normes, de la réglementation, d'éventuels compléments provenant de la PSSI, etc.

Cela correspond très directement à l'activité EBIOS RM d'établissement du socle de sécurité.

- Description du périmètre analysé (organisation, service, application ...)
- Cartographie des processus clés et des dépendances
- Liste des actifs critiques
- Besoins & critères (confidentialité, intégrité, disponibilité, gravité, etc.)
- Critères d'acceptation des risques



DEMARCHE DE GESTION DES RISQUES

ISO 27005 – Identification des risques

Processus consistant à rechercher, reconnaître et décrire les risques.

Elle implique de déterminer les sources et ce qui peut se produire. La cible est d'avoir à l'issue de cette activité **une liste de risques** pouvant mener à la concrétisation de conséquences menaçant **l'atteinte des objectifs de sécurité** identifiés.

Identifier:

- Actifs (VM, BS)
- Vulnérabilités
- Menaces
- Impacts



DEMARCHE DE GESTION DES RISQUES

ISO 27005 – Analyse des risques

Ce travail permet de projeter chaque risque en termes de gravité et de vraisemblance lors de l'évaluation.

- Choisir la méthode d'analyse
- Echelles Gravité & vraisemblance
- Niveau de risques

	Description détaillée de l'échelle
Mineure (1/4)	Aucun impact opérationnel ni sur les performances de l'activité ni sur la sécurité des personnes et des biens. La société surmontera la situation sans trop de difficultés (consommation des marges).
Significative (2/4)	Dégradation des performances de l'activité sans impact sur la sécurité des personnes et des biens. La société surmontera la situation malgré quelques difficultés (fonctionnement en mode dégradé).
Grave (3/4)	Forte dégradation des performances de l'activité, avec d'éventuels impacts significatifs sur la sécurité des personnes et des biens. La société surmontera la situation avec de sérieuses difficultés (fonctionnement en mode très dégradé).
Critique (4/4)	Incapacité pour la société d'assurer la sécurité des personnes et des biens (sa survie est menacée).

ÉCHELLE	DESCRIPTION
V4 quasi certain	La source de risque va certainement atteindre son objectif visé selon l'un des modes opératoires envisagés. La vraisemblance du scénario est très élevée.
V3 Très vraisemblable	La source de risque va probablement atteindre son objectif visé selon l'un des modes opératoires envisagés. La vraisemblance du scénario est élevée.
V2 Vraisemblable	La source de risque est susceptible d'atteindre son objectif visé selon l'un des modes opératoires envisagés. La vraisemblance du scénario est significative.
V1 Peu vraisemblable	La source de risque a peu de chance d'atteindre son objectif visé selon l'un des modes opératoires envisagés. La vraisemblance du scénario est faible.



DEMARCHE DE GESTION DES RISQUES

ISO 27005 – Evaluation des risques

Cette étape vise à **comparer les risques analysés aux critères d'acceptation définis**, pour déterminer lesquels doivent être traités.

- Priorisation
- Seuil d'acceptation

		GRAVITÉ				
		Mineure	Faible	Moyenne	Forte	Majeure
PROBABILITÉ	Quasi inévitable	5	10	15	20	25
	Probable	4	8	12	16	20
	Possible	3	6	9	12	15
	Faible	2	4	6	8	10
	Rarissime	1	2	3	4	5
		Risque non critique		Risque à surveiller		Risque à traiter en priorité



DEMARCHE DE GESTION DES RISQUES

ISO 27005 – Traitement des risques

L'ISO 27005 propose un traitement général du risque décomposé en plusieurs étapes :

- Choix l'option de traitement
- Formalisation d'un plan de traitement du risque
- Acceptation des risques résiduels



DEMARCHE DE GESTION DES RISQUES

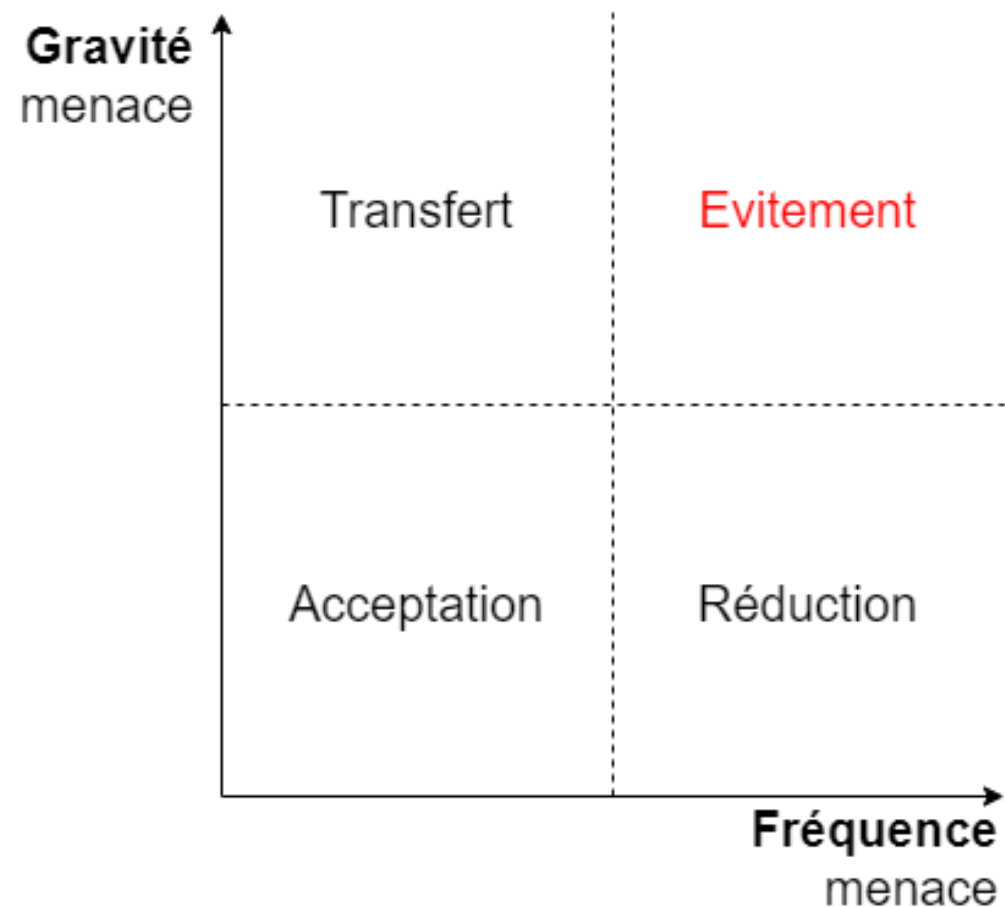
Stratégie de traitement des risques

Stratégie	Explication	Exemples
Réduction	Mettre en place des mesures pour diminuer probabilité d'occurrence ou impact du risque.	Installer firewall, activer la MFA, segmenter réseau pour réduire les risques d'intrusion.
Transfert	Faire porter le risque par un tiers (partie, totalité)	Souscrire assurance cyber, confier l'hébergement sécurisé à un prestataire certifié.
Acceptation	Assumer le risque tel quel. Le coût du traitement plus élevé que l'impact potentiel, ou que le risque est jugé acceptable.	Accepter que l'accès Wi-Fi invité ne soit pas isolé pour des raisons budgétaires, tout en documentant cette décision.
Évitement	Supprimer l'activité ou la situation à l'origine du risque.	Abandonner l'utilisation d'une application non sécurisée (shadow IT) plutôt que de chercher à la sécuriser.



DEMARCHE DE GESTION DES RISQUES

Stratégie de traitement des risques



		GRAVITÉ				
		Mineure	Faible	Moyenne	Forte	Majeure
PROBABILITÉ	Quasi inévitable	5	10	15	20	25
	Probable	4	8	12	16	20
	Possible	3	6	9	12	15
	Faible	2	4	6	8	10
	Rarissime	1	2	3	4	5
		Risque non critique		Risque à surveiller		Risque à traiter en priorité



CONFORMITÉ & REGLEMENTATIONS

Conformité

- S'assurer que l'organisation respecte l'ensemble des lois, réglementations, normes, politiques internes et exigences éthiques applicables à son activité;
- Mettre en place de contrôles et des processus et des contrôles démontrant le respect de ces obligations;
- Pour le système d'information, contrôle effectué au travers de l'analyse de risques.





CONFORMITÉ & REGLEMENTATIONS

Référentiels et réglementations applicables

Contexte

Vous avez débuté l'analyse de risque. Après avoir fixé le contexte, vous vous intéressez maintenant aux référentiels de bonnes pratiques et aux réglementations applicables qui pourraient constituer votre socle de sécurité*

Travail demandé

- Réaliser sous forme d'un tableau la liste des référentiels et réglementations applicables à Luminis Eclairage avec les colonnes suivantes: Nom , Type (référentiel, réglementation), Exigences clés, Applicabilité à Luminis (obligatoire, recommandé), Périmètre SI concerné , Objectifs / Raison, Conséquences si non mis en œuvre, Responsables impliqués
- Réaliser un ou deux slides sur les réglementations NIS2 et CRA (voir fiches synthèse)

(*) « 1ère couche de mesures de sécurité issues de l'état de l'art et de la conformité obligatoire » Amn Brains



CONFORMITÉ & REGLEMENTATIONS

Audit du référentiel

TYPE DE RÉFÉRENTIEL	NOM DU RÉFÉRENTIEL	ÉTAT D'APPLICATION	ÉCARTS	JUSTIFICATION DES ÉCARTS
Règles d'hygiène informatique et bonnes pratiques	Guide d'hygiène informatique de l'ANSSI	Appliqué avec restrictions	Règle 8 : identifier nommément chaque personne accédant au système et distinguer les rôles	Existence d'un compte <i>admin</i> non nominatif pour l'administration de l'ERP (solution propriétaire ne permettant pas l'administration par un autre compte)
			Règle 37 : définir et appliquer une politique de sauvegarde des composants critiques	Politique de sauvegarde en cours de rédaction par un groupe de travail



CONFORMITÉ & REGLEMENTATIONS

Plan de traitement des risques

A renseigner dès le début de la démarche, dès les premiers constats.



ID	Mesures	Références Guide d'hygiène	RGPD	R01 - Vol d'un document original	R02 - Compromission d'un document numérisé	R03 - Compromission des données apprenants	R04 - Destruction des supports de formation	R09 - Rançongiciel	R05 - Incendie	R06 - Panne de courant	R07 - Panne informatique	R08 - Pandémie	Urgence	Importante	Complexité	Freins et difficultés de mise en œuvre
M-01	Suivre une formation annuelle en lien avec les infrastructures de l'entreprise.	1	X		X	X	X	X					Moyenne	Elevée	Basse	Coûts (plusieurs k€), disponibilité des personnels)
M-02	Suivre un programme de formation en ligne lié à la cybersécurité	1	X		X	X	X	X					Moyenne	Elevée	Basse	Disponibilité des personnels)
M-03	Suivre une formation en ligne dédiée au développement sécurisé d'application	1	X		X	X	X	X					Basse	Elevée	Basse	





MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

Présentation

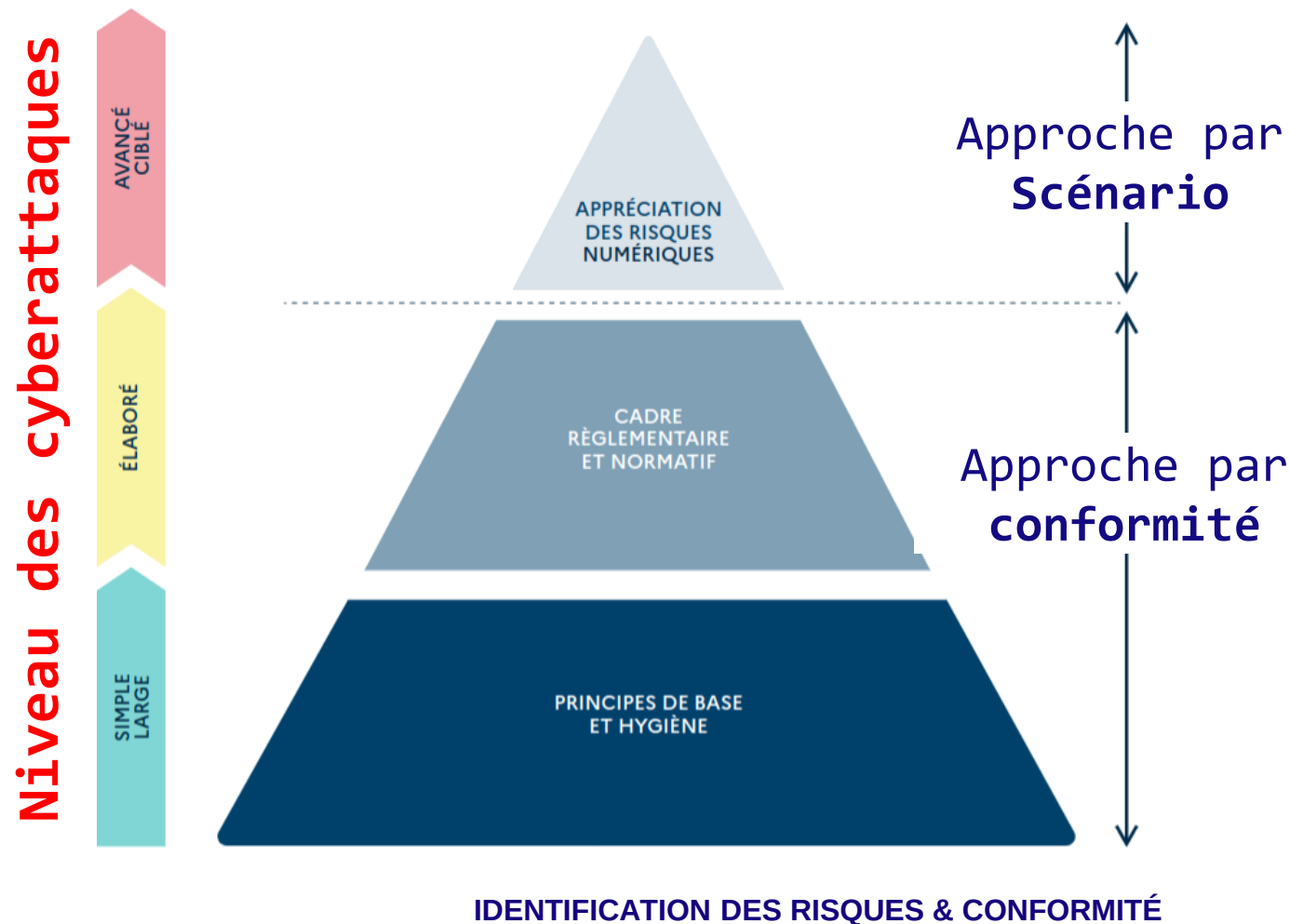
Expression des **B**esoins et **I**dentification des **O**bjectifs de **S**écurité

- Méthode d'analyse de risque française de référence
- Conforme à l'ISO 27005, réalisation de l'appréciation et du traitement des risques.
- Compréhension et responsabilité partagées des risques numériques entre décideurs et les acteurs opérationnels.
- Permettre aux dirigeants d'appréhender correctement ces risques, au même titre que d'autres de nature stratégique, financière, juridique, d'image, de ressources humaines ...



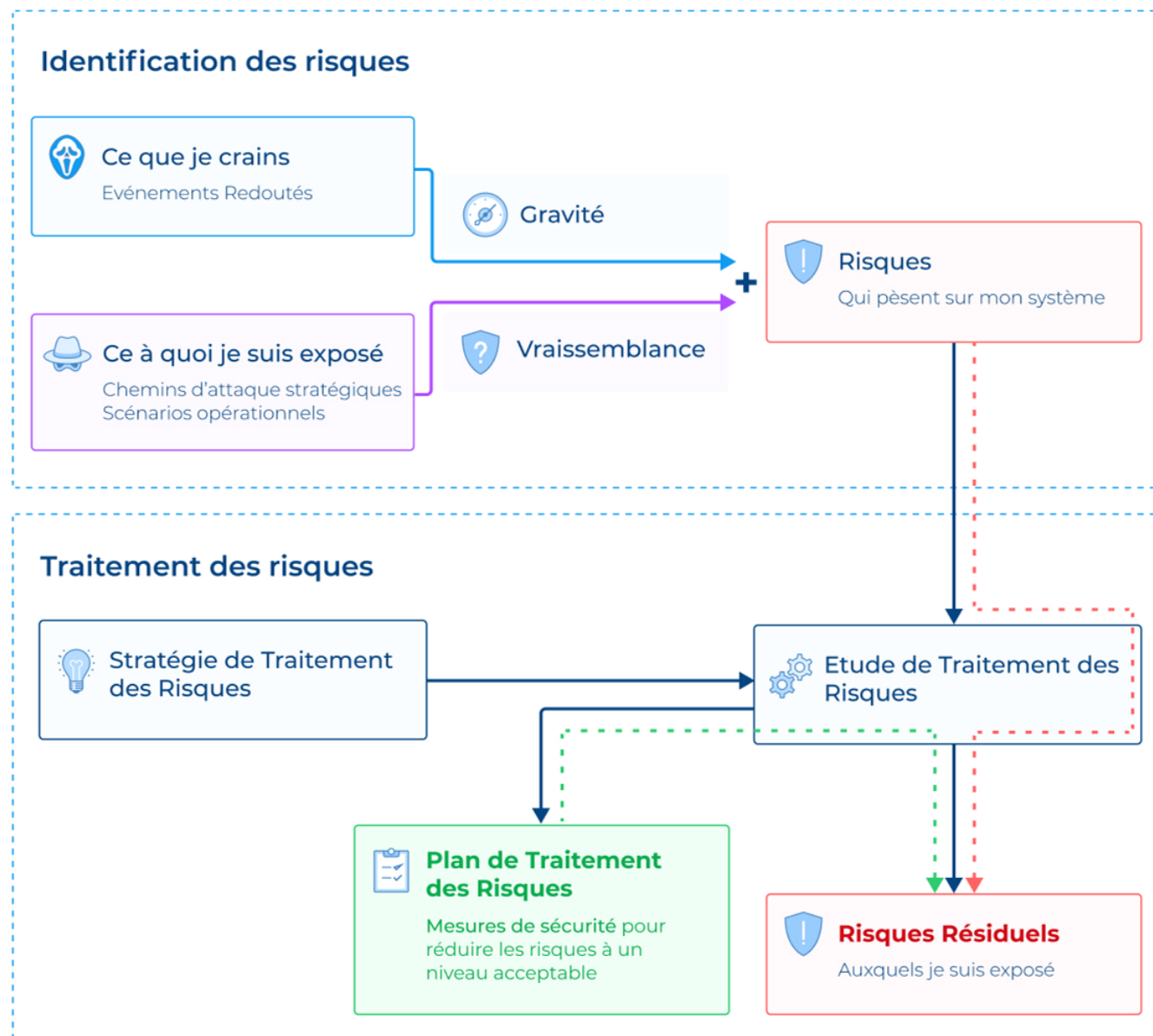
MISE EN ŒUVRE EBIOS RISK MANAGER

Pyramide des risques, exposition, démarche



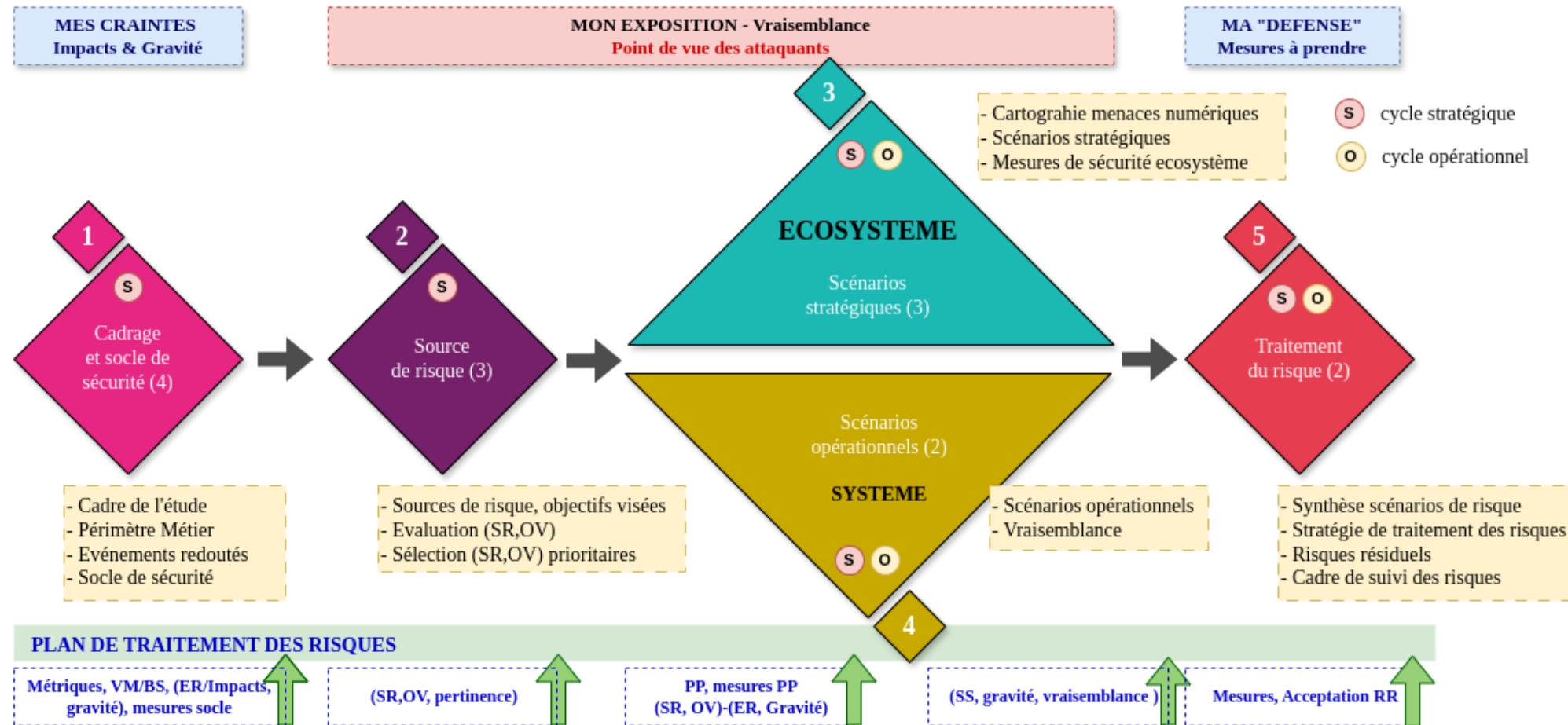
MISE EN ŒUVRE EBIOS RISK MANAGER

La démarche



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

Les ateliers

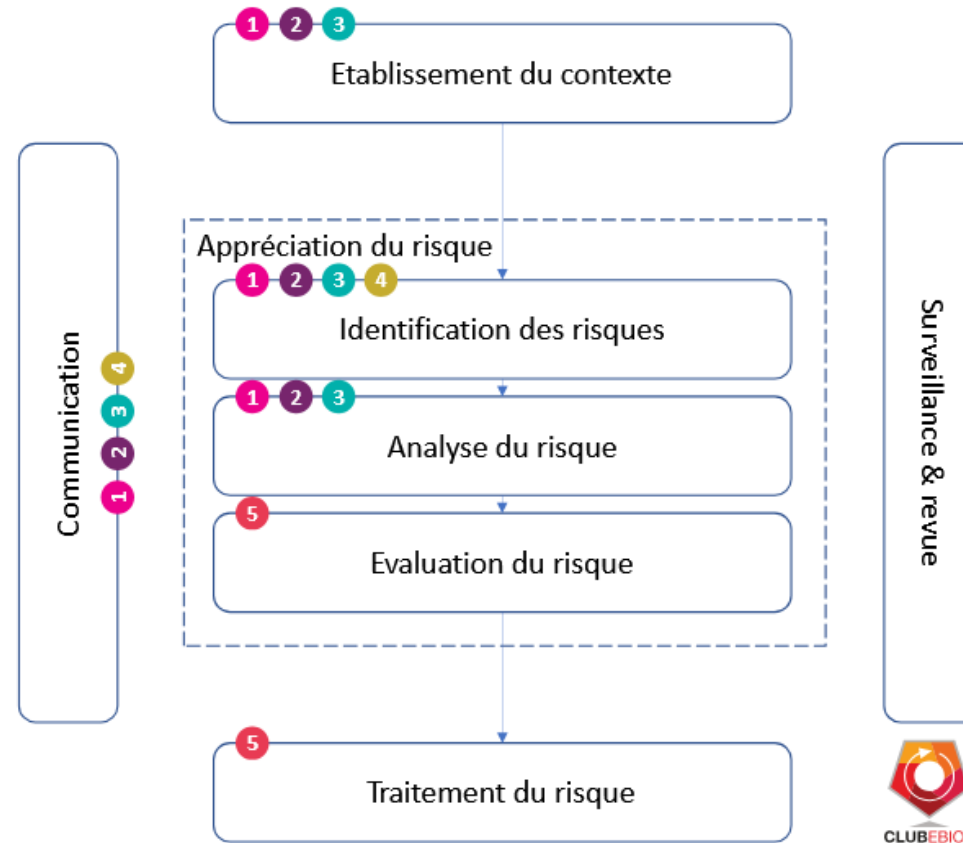


IDENTIFICATION DES RISQUES & CONFORMITÉ

MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

EBIOS RM conforme à ISO 27005

1. Cadrage et socle de sécurité (ER, gravité)
2. Source de risque (SR,OV)
3. Scénarios stratégiques [ER, (SR,OV)]
4. Scénarios opérationnels (vraisemblance)
5. Traitement du risque



MISE EN ŒUVRE EBIOS RISK MANAGER

Objectifs et ateliers à réaliser

OBJECTIF DE L'ÉTUDE	ATELIERS PRINCIPAUX À CONDUIRE OU EXPLOITER					
	1	2	3	4	5	
Identifier le socle de sécurité adapté à l'objet de l'étude	X					
Être en conformité avec les référentiels de sécurité numérique	X				X	Niveaux Simplifié
Évaluer le niveau de menace de l'écosystème vis-à-vis de l'objet de l'étude			X (note 1)			
Identifier et analyser les scénarios de haut niveau, intégrant l'écosystème		X	X			
Réaliser une étude préliminaire de risque pour identifier les axes prioritaires d'amélioration de la sécurité	X (note 2)	X	X (note 3)		X (note 4)	
Conduire une étude de risque complète et fine, par exemple sur un produit de sécurité ou en vue de l'homologation d'un système	X	X	X	X	X	Niveaux Renforcé
Orienter un audit de sécurité et notamment un test d'intrusion			X	X		
Orienter les dispositifs de détection et de réaction, par exemple au niveau d'un centre opérationnel de la sécurité (SOC)			X	X		



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

A1 – Cadrage et socle de sécurité

- Définir le cadre de l'étude (choix des ateliers à réaliser)
- Définir le périmètre métier
 - Missions
 - Valeurs Métier
 - Biens supports
- Identifier événements redoutés
- Déterminer le socle de sécurité

OBJECTIF DE L'ÉTUDE	ATELIERS PRINCIPAUX À CONDUIRE OU EXPLOITER				
	1	2	3	4	5
Identifier le socle de sécurité adapté à l'objet de l'étude	X				
Être en conformité avec les référentiels de sécurité numérique	X				X
Évaluer le niveau de menace de l'écosystème vis-à-vis de l'objet de l'étude			X (note 1)		
Identifier et analyser les scénarios de haut niveau, intégrant l'écosystème		X	X		
Réaliser une étude préliminaire de risque pour identifier les axes prioritaires d'amélioration de la sécurité	X (note 2)	X	X (note 3)		X (note 4)
Conduire une étude de risque complète et fine, par exemple sur un produit de sécurité ou en vue de l'homologation d'un système	X	X	X	X	X
Orienter un audit de sécurité et notamment un test d'intrusion			X	X	
Orienter les dispositifs de détection et de réaction, par exemple au niveau d'un centre opérationnel de la sécurité (SOC)			X	X	





MISE EN ŒUVRE EBIOS RISK MANAGER

A1.c Identifier les événements redoutés

Contexte

Grace à votre précédente mission où vous disposez d'une cartographie complète. Vous avez commencé à préremplir votre rapport qui comprend déjà un tableau de synthèse [VM, BS] (*voir J3 - Analyse de risques - Cadre & rapport Luminis*).

Travail demandé

- Choisir 2 ou 3 VM en lien avec l'activité commerciale et déterminer leurs besoins de sécurité
- Formuler plusieurs événements redoutés en lien avec ces VM
- Attribuer leur un niveau de gravité et justifier votre choix



Valeur métier	Besoin de sécurité concerné	Evènement redouté (ER)	Description ER	Impacts	Gravité
Commandes fournisseurs	Disponibilité	Erreur de saisie dans la commande fournisseur	Omission ou mauvaise saisie dans l'ERP ou Excel par un opérateur.	Blocage de la commande, rupture de stock, perte de temps	Significative
Données de stock	Intégrité	Erreur de mise à jour du stock	Oubli ou double saisie lors de l'ajustement de l'inventaire.	Commandes erronées, mauvaise gestion des stocks	Significative
CRM et gestion des	Intégrité	Données clients corrompues par	Suppression ou modification involontaire de	Mauvais traitement de commandes	Grave

Gestion de la relation commerciale - Appel d'offre

$C = 3/4$, $I = 3/4$

(Poste de travail, Serveur)

Compromission (vol) de la réponse à un AO

Perte du marché (300 k€) – Image

GRAVE



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

A2 – Sources de risques

- Identifier des (Sources de risque, Objectifs visés)
 - Profil d'attaquant (état, criminel ...)
 - Objectif (espionnage, influence, lucratif ...)
- Evaluer les couples
 - Calcul pertinence en fonction (motivation, ressource)
- Sélectionner les couples jugés prioritaires





MISE EN ŒUVRE EBIOS RISK MANAGER

A2 – Menaces > Sources de risques

Contexte

Vous progressez dans votre analyse de risques. Vous avez rassemblé autour de vous la DG, le RSI et les trois directeurs (CMC, PROD, MAINT)

Travail demandé

En vous appuyant sur « l'histoire » de Luminis, la connaissance de son écosystème, la connaissance de la menace cyber et le supplément EBIOS RM (p23), identifiez les 2 ou 3 couples (SR,OV) prioritaires.



Source de risque (SR)	Objectif visé (OV)	Cibles potentielles	Motivation	Besoins de sécurité visés
Cybercriminel	Chiffrement des	ERP, CRM, données clients	Paralyser l'activité pour extorquer	Confidentialité.

Gestion de la relation commerciale - Appel d'offre - C = 3/4, I = 3/4
(Poste de travail, Serveur)

ER01 - Compromission (vol) de la réponse à un AO - Perte du marché (300 k€) – Image - GRAVE

(SR,OV)

SR1 Concurrent direct – OV1 Dérober des documents commerciaux (M+++, R++ Elevé)

SR2 Prestataire mécontent – OV2 Perturber le fonctionnement du SI (M++, R++, Moyen)

SR3 Cybercriminel – OV3 Demander une rançon (M++ R+++ Elevé)

SR4 Employé mécontent – OV2 Perturber le fonctionnement du SI (M+++ R+ Moyen)

SR4	Concurrent direct	Voler des données clients ou offres commerciales pour obtenir un	Phishing cible pour accéder aux devis, contrats ou bases CRM	Externe – Ciblée (espionnage)	CRM, ERP, mails commerciaux	ER-05
-----	-------------------	--	--	-------------------------------	-----------------------------	-------



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

A3 – Scénarios stratégiques

- Cartographie des menaces de l'écosystème (parties prenantes critiques)
- Elaborer des scénarios stratégiques
- Définir des mesures de sécurité sur l'écosystème
 - PP + Chemin d'attaque
 - Mesures (exposition, fiabilité)
 - Menace initiale, menace résiduelle

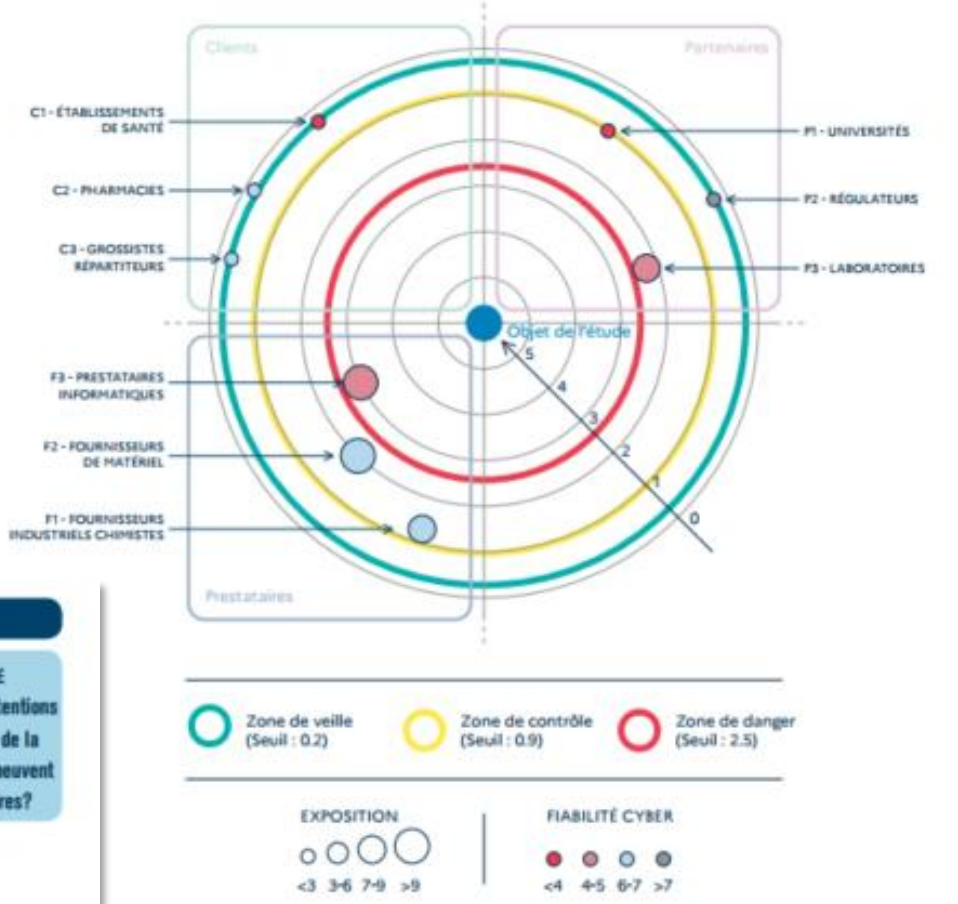
Exemple à traiter collectivement: DSI externalisée



MISE EN ŒUVRE EBIOS RISK MANAGER

Cartographie des parties prenantes

CATÉGORIE	PARTIE PRENANTE
Clients	C1 – Établissements de santé
	C2 – Pharmacies
	C3 – Dépositaires et grossistes répartiteurs
Partenaires	P1 – Universités
	P2 – Régulateurs
	P3 – Laboratoires
Prestataires	F1 – Fournisseurs industriels chimistes
	F2 – Fournisseurs de matériel de production
	F3 – Prestataire informatique



IDENTIFICATION DES RISQUES & CONFORMITÉ





MISE EN ŒUVRE EBIOS RISK MANAGER

A3 Scénarios stratégiques

Contexte

Vous progressez dans votre analyse de risques. Vous travaillez toujours avec la DG, le RSI et les trois directeurs (CMC, PROD, MAINT). Pour les ateliers sur les scénarios (A3 & A4), vous avez demandé la participation d'un expert des menaces cyber de votre cabinet (matérialisé par le recours à l'IA)

Travail demandé

- Identifiez 2 ou 3 parties prenantes « critiques » (à vérifier)
- Calculez son niveau de menace (complément p27)
- Identifiez un scénario stratégique (indirect, guide p50), en lien avec les VM commerciales

NB: Gravité du scénario = gravité de l'ER



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

A4 – Scénarios opérationnels

1 SS = 1 ou plusieurs scénarios opérationnels

- Elaborer des scénarios opérationnels
 - Connaitre (reconnaissance)
 - Rentrer (accès initial)
 - Trouver (déplacement)
 - Exploiter (OV de votre SR)
- Définir leur vraisemblance

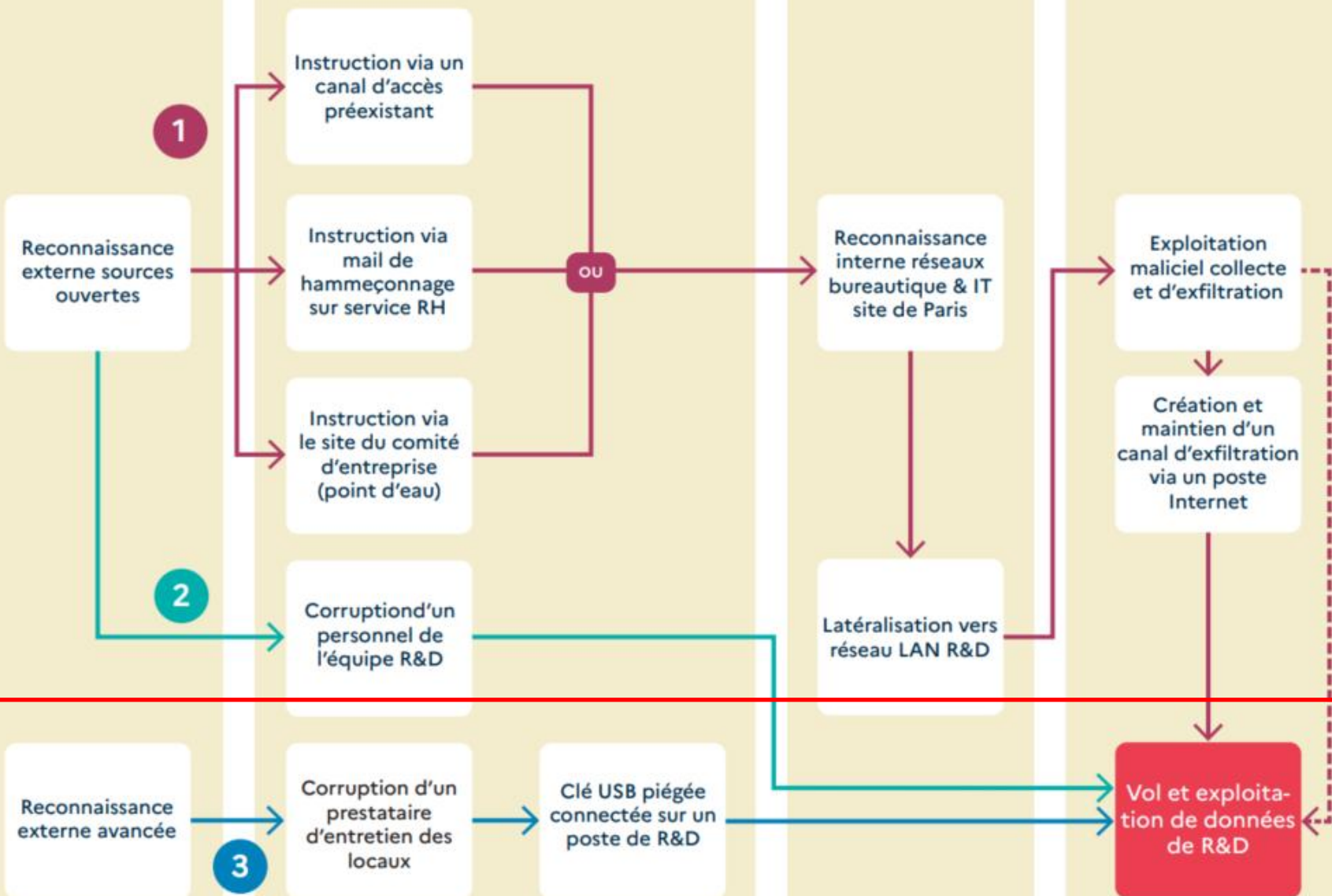


CONNAÎTRE

RENTRER

TROUVER

EXPLOITER



ATT&CK®



MISE EN ŒUVRE AVEC EBIOS RISK MANAGER

A5 – Traitement du risque

- Synthèse des scénarios de risque
 - matrice de risque initiale
- Définir les stratégies de traitement et les mesures de sécurité
 - Stratégies
 - Mesures (plan de traitement des risques)
- Fiches de risque résiduel (à valider)
- Définir le cadre du suivi des risques

		GRAVITÉ				
		Mineure	Faible	Moyenne	Forte	Majeure
PROBABILITÉ	Quasi inévitable	5	10	15	20	25
	Probable	4	8	12	16	20
	Possible	3	6	9	12	15
	Faible	2	4	6	8	10
	Rarissime	1	2	3	4	5
		Risque non critique		Risque à surveiller		Risque à traiter en priorité

MESURE DE SÉCURITÉ	SCÉNARIO DE RISQUE ASSOCIÉ	RESPONSABLE	FREINS ET DIFFICULTÉS DE MISE EN ŒUVRE	COÛT / COMPLEXITÉ	CHARGE ESTIMÉE	ECHÉANCE	PRIORITÉ	STATUT
--------------------	----------------------------	-------------	--	-------------------	----------------	----------	----------	--------

RR02 – Compromission d'un document numérisé sensible du fait d'une intrusion dans le réseau		
Description et analyse du risque résiduel : Le risque résiduel est lié au facteur humain (non-application des procédures) et à l'existence de faille « zero-day ».		
Événements redoutés concernés : ER5 - Compromission d'un document numérisé		
Mesures de traitement du risque existantes et complémentaires : - Politique de classification et protection des informations - Procédure de gestion des documents sensibles - Stockage sur des espaces dédiés - Renforcement de la sécurité du réseau (filtrage des équipements, segmentation du réseau, paramétrages des pare-feux, déploiement d'une EPP à l'état de l'art) - Sensibilisation des personnels - Assurance cyber		
Evaluation du risque résiduel		
Gravité initiale : 3/4	Vraisemblance initiale : 3/4	Niveau de risque initial
Gravité résiduelle : 2/4	Vraisemblance résiduelle : 2/4	Niveau de risque résiduel
Gestion du risque résiduel : Vérification de la bonne application des procédures et de la bonne mise en œuvre des procédures de sécurisation du SI.		





MISE EN ŒUVRE EBIOS RISK MANAGER

A5 Traitement du risque

Travail demandé

- Rédiger la fiche de risque résiduel pour un le scénario « vol de données par concurrent par compromission d'un collaborateur (ou d'un agent de service »).

RR02 – Compromission d'un document numérisé sensible du fait d'une intrusion dans le réseau		
Description et analyse du risque résiduel : Le risque résiduel est lié au facteur humain (non-application des procédures) et à l'existence de faille « zero-day ».		
Événements redoutés concernés : ER5 - Compromission d'un document numérisé		
Mesures de traitement du risque existantes et complémentaires : - Politique de classification et protection des informations - Procédure de gestion des documents sensibles - Stockage sur des espaces dédiés - Renforcement de la sécurité du réseau (filtrage des équipements, segmentation du réseau, paramétrages des pare-feux, déploiement d'une EPP à l'état de l'art) - Sensibilisation des personnels - Assurance cyber		
Evaluation du risque résiduel		
Gravité initiale : 3/4	Vraisemblance initiale : 3/4	Niveau de risque initial
Gravité résiduelle : 2/4	Vraisemblance résiduelle : 2/4	Niveau de risque résiduel
Gestion du risque résiduel : Vérification de la bonne application des procédures et de la bonne mise en œuvre des procédures de sécurisation du SI.		



GESTION DES RISQUES

Pour conclure

- La **sécurité du SI** est un levier stratégique, au service des objectifs métier de l'organisation;
- La **gestion des risques** permet d'identifier et de prioriser les risques qui pèsent sur les valeurs métier critiques
- Les **réglementations** (RGPD, NIS2, CRA...), de plus en plus prégnantes, imposent une gouvernance rigoureuse et une responsabilisation accrue des parties prenantes;
- La **méthode EBIOS RM** fournit une démarche opérationnelle en 5 ateliers pour piloter la sécurité efficacement
- L'étude de **cas Luminis Éclairage** a permis d'appliquer rapidement les différents concepts évoqués et la méthode EBIOS RM
- La **gestion des risques est un processus vivant**, à inscrire dans une dynamique continue d'amélioration.

